

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**



**PERFORMANCE WORK STATEMENT (PWS)
DEPARTMENT OF VETERANS AFFAIRS**

Office of Information & Technology
Compliance, Risk and Remediation

Modernized Enterprise eFOIA SaaS Solution

Date: February 23, 2026
VA-26-00037131
PWS Version Number: 1.0

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Contents

1.0	BACKGROUND.....	4
2.0	APPLICABLE DOCUMENTS.....	5
3.0	SCOPE OF WORK.....	8
4.0	PERFORMANCE DETAILS.....	8
4.1	PERFORMANCE PERIOD	8
4.2	PLACE OF PERFORMANCE	9
4.3	TRAVEL.....	9
5.0	SPECIFIC TASKS AND DELIVERABLES	9
5.1	PROJECT MANAGEMENT.....	16
5.1.1	CONTRACTOR PROJECT MANAGEMENT PLAN.....	16
5.1.2	REPORTING REQUIREMENTS	16
5.1.3	TECHNICAL KICKOFF MEETING	17
5.2	eFOIA RISK MANAGEMENT FRAMEWORK AND INFORMATION ASSURANCE	18
5.3	DATA MIGRATION (BASE PERIOD ONLY).....	18
5.4	EFOIA SYSTEM MAINTENANCE SUPPORT	19
5.5	EFOIA SOLUTION TRAINING.....	20
5.6	EFOIA LESSONS LEARNED	22
5.7	ASSESSMENT, AUTHORIZATION, AND CONTINUOUS MONITORING.....	22
5.7.1	IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED:.....	22
5.7.2	IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED: 24	
5.8	ENHANCED EXECUTIVE ANALYTICS AND DASHBOARD CAPABILITY	25
5.9	OPTION PERIOD 1	25
5.10	OPTION PERIOD 2	25
5.11	OPTION PERIOD 3	26
5.12	OPTION PERIOD 4	26
5.13	OPTIONAL TASK ONE – TRANSITION SUPPORT	26
5.14	OPTIONAL TASK TWO – ADDITIONAL STORAGE	27
5.15	OPTIONAL TASK THREE – ADDITIONAL CONCURRENT USERS	27
5.16	OPTIONAL TASK FOUR – APPLICATION PROGRAMMABLE INTERFACES (API) INTEGRATION ENABLEMENT AND CONFIGURATION	27
6.0	GENERAL REQUIREMENTS.....	28
6.1	ENTERPRISE AND IT FRAMEWORK.....	28
6.1.1	VA TECHNICAL REFERENCE MODEL.....	28
6.1.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS.....	28
6.1.3	FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)	29
6.1.4	INTERNET PROTOCOL VERSION 6 (IPv6)	30
6.1.5	TRUSTED INTERNET CONNECTION (TIC).....	31
6.1.6	STANDARD COMPUTER CONFIGURATION	31
6.1.7	VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM).....	31

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

6.1.8	PROCESS ASSET LIBRARY (PAL).....	32
6.1.9	AUTHORITATIVE DATA SOURCES.....	32
6.1.10	SOCIAL SECURITY NUMBER (SSN) REDUCTION	33
6.2	SECURITY AND PRIVACY REQUIREMENTS.....	34
6.2.1	POSITION/TASK RISK DESIGNATION LEVEL(S)	34
6.2.2	CONTRACTOR PERSONNEL SECURITY REQUIREMENTS	35
6.3	METHOD AND DISTRIBUTION OF DELIVERABLES	36
6.4	PERFORMANCE METRICS	37
6.5	FACILITY/RESOURCE PROVISIONS.....	38
6.6	GOVERNMENT FURNISHED PROPERTY	39
6.7	SHIPMENT OF HARDWARE OR EQUIPMENT	39
ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED		39
ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE.....		45

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Office of Information and Technology (OIT), Quality, Performance, and Risk, Office of Quality Compliance, strives to provide high quality, effective, and efficient information technology services that support those responsible for delivering care to Veterans across all points of care in a timely and compassionate manner. VA relies on information management and information technology systems to support mission objectives and enable effective program operations.

The Freedom of Information Act, 5 U.S.C. 552, as amended by Public Law No. 110-175, establishes the public's right of access to federal agency records, except where records are protected from disclosure by statutory exemptions or exclusions. Executive Order 13392 and the Openness Promotes Effectiveness in our National Government Act further amended FOIA and directed agencies, including VA, to improve FOIA program management and provide more customer focused service. VA's web based Electronic Freedom of Information Act system was developed in response to these statutory and policy requirements. More recently, the STRONG Veterans Act of 2022 and the Joseph Maxwell Cleland and Robert Joseph Dole Memorial Veterans Benefits and Health Care Improvement Act of 2022 reinforced the need for modern eFOIA capabilities and reduced response timelines for VA FOIA programs.

The VA FOIA Office requires an eFOIA system capable of preserving, collecting, processing, reviewing, analyzing, and producing electronically stored information in compliance with legal obligations under the Federal Rules of Civil Procedure and the Freedom of Information Act, 5 U.S.C. 552, as amended.

VA FOIA operations must support time sensitive requests involving large volumes of electronically stored information, including the ability to process, upload, and analyze millions of records to meet court ordered deadlines associated with litigation, investigations, FOIA requests, and congressional oversight. Failure to meet these requirements increases the risk of court sanctions and costly or unmerited settlements.

Currently, the VA FOIA Office manages approximately 12 terabytes of data that will carry forward from the legacy system, which reached end of life on April 30, 2024, with daily ingestion of standard and non standard documents, audio files, and video files. The VA Central Office FOIA records retention schedule established by the National Archives and Records Administration is six years, excluding litigation holds, appeals, and related exceptions. The VA FOIA Office requires support for approximately 900 users during each period of performance, with the ability to adjust the number of licenses based on program needs. Individual requests may range in size from more than 150 gigabytes to a single page document. In fiscal year 2022, the VA FOIA

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

program received approximately 23,000 requests, increasing to approximately 71,200 requests in fiscal year 2023, and more than 120,000 requests in fiscal year 2024.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. 44 U.S.C. § 3541-3549, "Federal Information Security Management Act (FISMA) of 2002"
2. "Federal Information Security Modernization Act of 2014"
3. Federal Information Processing Standards (FIPS) Publication 140-2, "Security Requirements for Cryptographic Modules"
4. FIPS Pub 199, "Standards for Security Categorization of Federal Information and Information Systems," February 2004
5. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
6. FIPS Pub 201-2, "Personal Identity Verification of Federal Employees and Contractors," August 2013
7. 10 U.S.C. § 2224, "Defense Information Assurance Program"
8. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
9. 5 USC 552 (FOIA) and the VA, 38 CFR Chapter 1 Part 1 & 2
10. Public Law 109-461, Veterans Benefits, Health Care, and Information Technology Act of 2006, Title IX, Information Security Matters
11. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964"
12. VA Directive 0710, "Personnel Security and Suitability Program," June 4, 2010, <https://www.va.gov/vapubs/index.cfm>
13. VA Handbook 0710, "Personnel Security and Suitability Program," May 2, 2016, <https://www.va.gov/vapubs/index.cfm>
14. VA Directive and Handbook 6102, "Internet/Intranet Services," August 5, 2019
15. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," January 18, 2017
16. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
17. 32 C.F.R. Part 199, "Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)"
18. NIST SP 800-66 Rev. 1, "An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule," October 2008
19. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended, January 18, 2017
20. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
21. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021
22. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021
23. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," March 12, 2019

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

24. VA Handbook 6500.5, "Incorporating Security and Privacy into the System Development Lifecycle," March 22, 2010
25. VA Handbook 6500.6, "Contract Security," March 12, 2010
26. VA Handbook 6500.8, "Information System Contingency Planning," April 6, 2011
27. VA Handbook 6500.10, "Mobile Device Security Policy," February 15, 2018
28. VA Handbook 6500.11, "VA Firewall Configuration," August 22, 2017
29. OIT Process Asset Library (PAL), <https://www.va.gov/process/> . Reference Process Maps at <https://www.va.gov/process/maps.asp> and Artifact templates at <https://www.va.gov/process/artifacts.asp>
30. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
31. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
32. VA Handbook 6508.1, "Procedures for Privacy Threshold Analysis and Privacy Impact Assessment," July 30, 2015
33. VA Handbook 6510, "VA Identity and Access Management," January 15, 2016
34. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
35. VA Directive 6300, "Records and Information Management," September 21, 2018
36. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
37. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
38. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
39. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015
40. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014
41. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
42. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
43. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
44. Federal Identity, Credential, and Access Management (FICAM) Roadmap and Implementation Guidance, December 2, 2011, (NOTE: Part A of the FICAM Roadmap and Implementation Guidance, v2.0, was replaced in 2015 with an updated Architecture (<https://arch.idmanagement.gov/#what-is-the-ficam-architecture>))
45. NIST SP 800-116 Rev 1, "Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access," June 2018
46. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, "Digital Identity Guidelines," updated March 02, 2020

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

47. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
48. NIST SP 800-164, "Guidelines on Hardware-Rooted Security in Mobile Devices (Draft)," October 2012
49. Draft National Institute of Standards and Technology Interagency Report (NISTIR) 7981, "Mobile, PIV, and Authentication," March 2014
50. VA Memorandum, VAIQ #7100147, "Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12)," April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
51. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
52. VA Memorandum "Personal Identity Verification (PIV) Logical Access Policy Clarification," July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
53. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
54. OMB Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative," September 12, 2019
55. OMB Memorandum M-08-23, "Securing the Federal Government's Domain Name System Infrastructure," August 22, 2008
56. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (Public Law 110–140), December 19, 2007
57. Section 104 of the Energy Policy Act of 2005, (Public Law 109–58), August 8, 2005
58. Executive Order 13834, "Efficient Federal Operations," dated May 17, 2018
59. Executive Order 13221, "Energy-Efficient Standby Power Devices," August 2, 2001
60. VA Directive 0058, "VA Green Purchasing Program," July 19, 2013
61. VA Handbook 0058, "VA Green Purchasing Program," July 19, 2013
62. Office of Information Security (OIS) VAIQ #7424808 Memorandum, "Remote Access," January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
63. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
64. "Veteran Focused Integration Process (VIP) Guide 4.0," January 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>
65. VA Memorandum "Proper Use of Email and Other Messaging Services," January 2, 2018, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
66. "DevSecOps Product Line Management Playbook" version 2.0, May 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
67. NIST SP 500-267B Revision 1, "USGv6 Profile," November 2020
68. OMB Memorandum M-21-07, "Completing the Transition to Internet Protocol Version 6 (IPv6)," November 19, 2020
69. Social Security Number (SSN) Fraud Prevention Act of 2017
70. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

71. VAAR Part 804.1303, Contract Clause Requiring Compliance with Personal Identity Verification of Contractor Personnel:
<https://www.va.gov/oal/library/vaar/vaar804.asp#8041303>
72. VAAR 804.1970, Information Security Policy – Contractor General Responsibilities: <https://www.va.gov/oal/library/vaar/vaar804.asp#8041970>
73. FedRAMP's Continuous Monitoring Strategy Guide:
https://www.fedramp.gov/assets/resources/documents/CSP_Continuous_Monitoring_Strategy_Guide.pdf

3.0 SCOPE OF WORK

The Contractor shall provide a Commercial Off the Shelf (COTS) Modernized Enterprise Electronic Freedom of Information Act (eFOIA) Software as a Service solution, inclusive of, project management, project planning, training, data migration, human centered design, application performance monitoring and alerting, risk management, information assurance, operations and maintenance, and lessons learned.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The Period of Performance (PoP) shall consist of a 12-month base period plus four 12-month option periods and four optional tasks.

Any work at the Government site shall not take place on Federal holidays or weekends unless directed by the Contracting Officer (CO).

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractor's place of performance in their proposal submission.

Work may be performed at remote locations with prior approval of the Government Program Manager (PM). The Contractor shall maintain an online presence during normal Monday through Friday business hours. After-business-hours, emergency, and pre-approved scheduled work may be performed at remote locations with prior approval of the Government PM as stated in this PWS.

4.3 TRAVEL

The Government does not anticipate travel under this effort to perform the tasks associated with the effort.

5.0 SPECIFIC TASKS AND DELIVERABLES

Normal business hours are Monday throughout Friday from 9:00am to 5:00pm Eastern Time.

The Contractor shall provide a Commercial Off-the-Shelf (COTS) Modernized Enterprise eFOIA Software as a Service (SaaS) solution, hereafter referred to as the "COTS eFOIA SaaS solution", "eFOIA SaaS solution" or "the solution".

The Contractor shall deliver a fully configured, deployed, and baselined solution within 30 calendar days of award and shall achieve go live within 90 calendar days of award. A baseline solution shall mean that system configuration is complete, user roles and permissions are established, required workflows are implemented, and the solution is ready for VA testing. Go live shall mean that the solution is operating with full functionality to include VA production data is being processed in the solution and designated FOIA offices are able to intake, track, review, redact, and close requests in the production environment.

The Contractor shall provide all application hosting, licensing, operational environments, help desk and system support, and maintenance required for VA use and shall allow VA-directed hybrid or split data storage arrangements, as applicable.

The Contractor shall provide all required installation, configuration, data migration, testing, deployment support, product support, technical support, and Service Level Agreements.

The Contractor shall ensure the solution is operational, reliable, and available for VA use at least 99.9 percent of the time each calendar month, excluding VA approved planned maintenance.

The Contractor shall ensure all required salient characteristics are fully available and operational at go live and shall be expandable or scalable during the period of performance without requiring solution redesign or replacement. The requirements in

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

this section establish the minimum salient characteristics required to support VA FOIA program needs and are not listed in order of importance.

The solution shall meet at a minimum all of the following salient characteristics:

1. The solution shall have a current FedRAMP Moderate authorization and meet FISMA Moderate requirements at the time of proposal submission. The authorization and controls shall apply to the complete solution proposed for VA use, including hosting, core application components, supporting services, and any integrated modules.
2. The solution shall have API(s) that connect the solution to VA information management systems such as those that handle VA Privacy, records management, identity, reporting, payment information or payment transactions, and VA-owned databases. The solution shall support both real-time and scheduled data exchanges, including transactional data feeds, metadata synchronization, and reporting outputs, using industry-standard protocols and data formats, i.e., Representational State Transfer (REST). This requirement does not mandate public access to the solution from FOIA.gov.
3. The solution shall process Freedom of Information Act requests, Privacy Act requests under 5 U.S.C. 552a, and combined FOIA and Privacy Act requests. Unless a requirement is expressly limited to FOIA or Privacy Act processing, all requirements in this section apply equally to FOIA requests, Privacy Act requests, and combined FOIA and Privacy Act requests. The solution shall comply with 5 U.S.C. 552, 5 U.S.C. 552a, applicable Department of Justice Office of Information Policy guidance, and VA FOIA and Privacy Act policies and procedures.
4. The solution shall provide the ingestion, viewing, processing, and export of large electronic files, including documents, images, audio, and video. The solution shall:
 - Accept and export all commonly used electronic file formats, including but not limited to PDF, DOCX, XLSX, PPTX, TXT, JPG, PNG, MP4, and WAV, and any format required for FOIA processing during the period of performance.
 - Be able to introduce into the solution any additional file formats introduced during the period of performance without requiring re-competition or solution redesign.
 - Support reliable uploads and exports of individual files of at least 20 GB at award, including the ability to complete transfers without timeouts and to

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

resume interrupted uploads or downloads without data loss, with the capability to scale to larger file sizes during the period of performance without requiring solution replacement.

- By exception, support VA directed uploads and exports of files larger than the standard maximum file size for specific FOIA requests.
 - Maintain the integrity and metadata of files during transfer and export and ensure confidentiality and integrity of data while in transit and at rest.
5. The solution shall provide document review capabilities that support FOIA workflows including viewing and navigating large record sets; automated redaction for text, images, audio, and video across all supported file formats; review tracking; multiple review layers; full revision history; applying a single redaction action automatically to all occurrences of the same information within a record set; and de-duplication of identical content within a request to reduce reviewer workload.
 6. The solution shall provide a public-facing portal that allows requesters to submit FOIA requests, track submission status, and securely receive responsive records. The portal shall require multifactor authentication and integrate with identity verification services that meet federal digital identity standards as defined in NIST 800-63.
 7. The solution shall support at least one VA-approved, federally recognized digital identity provider, such as Login.gov or ID.me, at proposal submission and shall be capable of supporting additional VA-approved digital identity providers during the period of performance.
 8. The solution shall provide comprehensive search capabilities across all content within a request, including Optical Character Recognition-generated text, embedded text, handwritten content that can be recognized by the solution, audio transcripts, and video transcripts. Search functions shall support keyword, Boolean, proximity, and metadata-based queries and shall return results across all documents, media, and derived content associated with the request.
 9. The solution shall provide automated processing capabilities that support FOIA operations, including Optical Character Recognition for documents and embedded images, file level de duplication, content analytics to identify sensitive information, classify materials, and prioritize items for review, and operational analytics to forecast workload, processing times, and request trends for FOIA program management.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

10. The solution shall provide a configurable dashboard that meets FOIA reporting requirements and supports operational oversight. The dashboard shall display metrics including Average Processing Time for Simple, Complex, and Expedited requests, and shall allow metrics to be viewed and filtered by individual user, organizational component, office, administration, or other VA-defined grouping. Record Retrieval Response Time, System Health, Uptime Monitoring, Active User Counts, and a user work summary that reflects individual and aggregate workload activity. The dashboard shall also provide additional commonly used FOIA program management metrics and shall allow VA to modify or add displayed metrics during the period of performance
11. The solution shall include a Substantial Interest review process or an equivalent second level review capability that allows designated users to route, track, and document additional review requirements before release. The solution shall provide visibility into review status, reviewer actions, and completion time for all second level reviews.
12. The solution shall include a FOIA Reading Room that provides public access to records designated for proactive disclosure. The Reading Room shall allow hosting, searching, browsing, and downloading of posted records and shall support metadata tagging to facilitate organization and retrieval. The solution shall preserve prior versions of posted records when updates or replacements occur and shall maintain a history of changes for audit and compliance purposes.
13. The solution shall provide a correspondence management capability that supports creation, editing, versioning, and use of standardized FOIA communication templates. Templates shall provide auto population with request data, requester information, deadlines, document status, fee information, and other fields defined by VA. Users shall be able to create new templates or modify existing templates without vendor assistance, and templates shall support attachments, conditional logic, and customizable formatting. The solution shall maintain version control for all templates, including tracking changes, preserving prior versions, and allowing VA to restore or review earlier versions. Templates shall be usable for email correspondence, solution generated messages, or other communication channels supported by VA. The solution shall provide request tracking and advanced document management capabilities that support the full FOIA lifecycle in accordance with NARA General Records Schedule 4.2. The solution shall allow users to organize, assign, monitor, and process requests and

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

shall provide tools for version control, document history, retention tagging, and efficient navigation of large record sets.

14. The solution shall provide the ability to analyze and classify inbound requests submitted through the public portal or other supported intake channels. The solution shall identify whether an inbound submission is a FOIA request, a Privacy Act request, a combined FOIA or Privacy Act request, an invalid or unperfected request, or a submission that is not a proper FOIA request. Based on VA defined rules, the solution shall recommend or generate disposition actions including routing, closure, or return for clarification. When enabled by VA, the solution shall automatically close requests identified as improper, invalid, or duplicate submissions. The solution shall also identify duplicate or substantially identical requests from the same requester or with similar content and shall provide tools to consolidate or close such requests in accordance with VA policy.
15. All automated and recommended actions performed by the solution shall be fully logged. Logged information shall include, at a minimum, the classification determination, action taken, date and time of the action, and the rule or condition that triggered the action.
16. The solution shall generate reports summarizing automated and recommended actions, and VA shall control the frequency, recipients, and distribution schedule of such reports.
17. The solution shall also maintain a complete, immutable audit log of all user actions and solution actions, including document edits, redaction events, classification decisions, and access events. Audit logs shall include user identifier, timestamp, action type, affected records, and prior and resulting states. Audit logs and reports shall be exportable in machine-readable formats suitable for compliance, litigation, and oversight reviews (e.g., CSV, JSON, or XML).
18. The solution shall have and maintain a complete data dictionary. The data dictionary shall define all data elements used in the solution, including column or field names, descriptions, data types, allowable values, data relationships, and business rules. The data dictionary shall cover request data, requester data, workflow fields, document metadata, reporting fields, solution generated fields, and any fields used for interfaces or integrations. The solution shall update the data dictionary as part of the solution's configuration management process

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

whenever configuration changes occur during the period of performance and shall be provided to VA in a machine readable format such as CSV and/or JSON.

19. The solution shall support processing of Privacy Act requests and combined FOIA and Privacy Act requests within the same system used for FOIA processing. The solution shall provide the capability to apply Privacy Act access provisions and exemptions, in accordance with applicable law and Department of Justice guidance. The solution shall allow Privacy Act determinations, redactions, correspondence, and final responses to be documented, tracked, and produced within the solution without requiring use of external records management or response tools.
20. The solution shall comply with Federal accessibility requirements, including Section 508 of the Rehabilitation Act, and shall meet all VA 508 compliance standards for both the requester portal and the internal user interface. The Contractor shall ensure that all functionality, content, and outputs generated by the solution are accessible to users with disabilities.
21. The solution shall be web-based and accessible from any VA office or VA-operated location without installation of client software. The solution shall support secure access through standard web browsers and shall function consistently across VA network environments, meaning users experience the same core functionality regardless of VA location, including VA headquarters, field offices, and remote VA facilities.
22. The solution shall support the requirements of 5 U.S.C. 552, Department of Justice Office of Information Policy (OIP) guidance, and VA FOIA policy by tracking deadlines, documenting requester communications, recording processing actions, and capturing final determinations. The solution shall calculate statutory due dates, flag approaching or overdue deadlines, maintain a complete communication history, and allow users to document exemption decisions, releases, and closures in accordance with FOIA and VA policy. The solution shall also support FOIA program reporting and compliance by generating standard and ad hoc reports using solution data. The solution shall provide the ability to produce customized reports based on VA-defined criteria, including filtering and aggregation by person, organization, office, administration, time period, and other VA-defined parameters. The solution shall generate reports that comply with Department of Justice OIP reporting requirements, including Monthly, Quarterly, and Annual FOIA reports. All reports shall be

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

exportable in commonly used electronic formats, including but not limited to PDF, CSV, and XLSX, without requiring vendor intervention.

23. The solution shall fully support VA FOIA program needs and scalability requirements (i.e., additional users and storage), including increased user capacity, expanded data volume, and additional FOIA offices or components added during the period of performance without requiring redesign of the solution. The solution shall keep up with any future FOIA requirements imposed by the federal government.
24. The Contractor shall configure the COTS eFOIA SaaS solution to support VA-owned domain routing through a Canonical Name (CNAME) record. The solution shall allow VA to direct a VA-controlled **.gov** hostname to the Contractor's service endpoint without exposing the underlying vendor URL. The Contractor shall provide all required target values, DNS instructions, and security validation details necessary for VA to establish and maintain the CNAME. The Contractor shall ensure the service remains fully functional and accessible through the VA-designated domain.
25. The solution shall support at least 900 concurrent active users. The solution shall allow expansion of concurrent user capacity during the period of performance without requiring solution redesign or replacement and without degradation of performance.
26. The solution shall provide a minimum of 15 terabytes of active storage for FOIA records managed in accordance with applicable National Archives and Records Administration (NARA) retention schedules. The solution shall allow expansion of storage capacity during the period of performance without requiring solution redesign or replacement and without degradation of performance.
27. The solution shall provide the capability to include a maximum of 15 fully segregated and isolated operational environments within the same SaaS platform. Each segregated environment shall be logically and administratively isolated such that data, records, metadata, indexes, audit logs, searches, analytics, and reporting are not visible, discoverable, or accessible outside of the explicitly authorized user group for that environment. Access shall be restricted exclusively to users granted permission for the segregated environment, and users without access, including enterprise, system, or program administrators for other environments, shall have no visibility into the existence, contents, or activity of the segregated environment. Each segregated environment shall provide the same functional capabilities as the primary eFOIA SaaS environment, including

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

intake, processing, review, redaction, reporting, auditing, and compliance features, and segregation shall be enforced through technical controls consistent with Federal cybersecurity standards rather than procedural controls alone.

Deliverable:

- A. COTS Modernized Enterprise eFOIA SaaS Solution

5.1 PROJECT MANAGEMENT

5.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that describes the Contractor's approach, timeline, and tools for executing the contract, including the project schedule, milestones, risks, and resource requirements. The CPMP shall describe how the Contractor will coordinate and fulfill planned, routine, and ad hoc reporting requirements identified in the PWS.

The CPMP shall also describe the Contractor's approach to risk management, system continuity, and operational resilience, including the existence and maintenance of a Disaster Recovery and Business Continuity Plan appropriate to the solution and hosting architecture. The Contractor shall make such plans available to the Government for review upon request. Government review and feedback shall not constitute approval and shall not relieve the Contractor of responsibility for solution availability, data protection, or recovery operations.

The initial baseline CPMP shall be submitted for VA concurrence and updated in accordance with Section B – Price Schedule. The Contractor shall maintain the VA-approved CPMP throughout the period of performance and update it as necessary to reflect material changes to project execution, solution architecture, or risk posture.

Deliverable:

- A. Contractor Project Management Plan

5.1.2 REPORTING REQUIREMENTS

The Contractor shall provide the Contracting Officer's Representative with a Monthly Progress Report in an electronic format agreed upon by VA. The report shall be structured and concise and shall support month-to-month comparison and trend analysis.

The report shall summarize work completed during the reporting period, work planned for the subsequent reporting period, and any changes from the prior report. The report shall identify risks, issues, and deviations from the Contractor Project Management

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Plan, including impacts, mitigation actions, and changes in status since the prior reporting period. Narrative content shall be limited to explanations of variances, risks, or issues and shall not be used for general status reporting.

The report shall include a tabular status of all Information and Communication Technology deliverables, including planned and actual dates, current status, variances, and Section 508 conformance status.

The Contractor shall monitor performance of all PWS tasks against the CPMP and report any deviations. The Monthly Progress Report shall include updates on Risk Management Framework activities and solution training only when there are changes in status, identified risks, completed activities, or upcoming actions requiring VA awareness or decision.

The Contractor shall maintain regular communication with VA to ensure that emerging issues are visible to both parties and addressed prior to escalation.

Deliverable:

A. Monthly Progress Report

5.1.3 TECHNICAL KICKOFF MEETING

The Contractor shall support and facilitate a Technical Kickoff Meeting to introduce the Contractor team, confirm roles and responsibilities, review the high-level program approach, and discuss initial timelines and expectations. The Technical Kickoff Meeting shall occur no later than five business days after contract award at a time coordinated with VA.

The Contractor shall prepare and provide presentation materials or equivalent documentation to support the meeting. VA will review the materials in advance and may provide comments prior to the meeting. The Technical Kickoff Meeting materials shall include, at a minimum:

1. Points of contact for VA and Contractor personnel, including roles and responsibilities
2. An overview of the draft Contractor Project Management Plan
3. Current FedRAMP authorization status and VA Temporary Authority to Operate or Authority to Operate status

The Contractor shall document meeting outcomes and provide meeting minutes to VA.

Deliverables:

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

- A. eFOIA Technical Kickoff Meeting Materials
- B. eFOIA Technical Kickoff Meeting Minutes

5.2 EFOIA RISK MANAGEMENT FRAMEWORK AND INFORMATION ASSURANCE

The Contractor shall ensure that the solution complies with applicable VA security requirements and federal cybersecurity standards, including the National Institute of Standards and Technology (NIST) Risk Management Framework, Office of Management and Budget guidance, and VA information security policies for systems processing personally identifiable information (PII).

The Contractor shall provide Risk Management Framework (RMF) documentation that identifies solution risks, associated mitigation strategies, and ongoing risk monitoring activities. The documentation shall include the results of periodic security assessments, vulnerability scans, and other security testing performed to evaluate solution security posture. The Contractor shall maintain and update RMF documentation throughout the period of performance in accordance with VA direction and applicable security requirements.

Deliverable:

- A. Risk Management Framework Documentation

5.3 DATA MIGRATION (BASE PERIOD ONLY)

Most of the existing FOIA data currently resides in VA's legacy system called FOIAXpress, but some data may come from outside FOIAExpress.

The Contractor shall migrate existing FOIA data from FOIAXpress to the COTS eFOIA SaaS solution at the beginning of the base period of performance. Migration may include all FOIA data or a subset of FOIA data based on VA decisions. Data migration shall include the transfer of VA provided FOIA records, metadata, and supporting information necessary to begin production operations.

The Contractor shall provide a Data Migration Plan that describes the Contractor's approach, scope, tools, sequencing, validation, and rollback procedures for migrating FOIA data from FOIAXpress to the COTS eFOIA SaaS solution. The plan shall address both full and partial migration scenarios and shall describe how data integrity, metadata, audit history, and retention attributes will be preserved. Upon VA approval of the Data Migration Plan, the Contractor shall migrate only the FOIA data identified by VA.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Deliverable:

A. Data Migration Plan

5.4 EFOIA SYSTEM MAINTENANCE SUPPORT

The Contractor shall provide solution maintenance to include release management, help desk support, incident/issue resolution, user support, and reporting services for the solution.

Maintenance. The Contractor shall implement software updates and upgrades in accordance with VA Handbook 6500 and in coordination with VA to avoid disruption of FOIA operations. The Contractor shall limit planned maintenance to periods approved in advance by VA. Planned maintenance shall not exceed four hours per calendar month and shall not occur during VA business hours unless expressly authorized by VA. VA may authorize additional planned maintenance time when necessary for security updates, system upgrades, or other critical activities, provided the Contractor obtains prior written approval from the COR and coordinates timing to minimize operational impact.

Release Management. The Contractor shall provide advance notice to VA of all planned system updates, enhancements, and releases. The Contractor shall maintain a continuously updated set of solution release notes the Weekly Maintenance Logs, to document new features, changes, fixes, and known issues. The Contractor shall provide a proposed update and release schedule and shall not deploy updates that impact functionality, workflows, or user experience without prior VA concurrence on release timing and scope. Emergency or security-driven updates shall be coordinated with VA as soon as practical and documented in the release notes.

Help Desk Support. The Contractor shall provide 24x7x365 help desk support, including on-call technical support and remedial user assistance as needed. During VA business hours, the help desk shall acknowledge all tickets with a non-automated response within one business hour. Outside VA business hours, automated acknowledgment is acceptable, provided that a non-automated response is issued no later than the next VA business hour. For all incidents, automated notification is acceptable outside VA business hours, with human follow-up provided no later than the next business hour unless VA requests after-hours escalation.

Incident/Issue Resolution. The Contractor shall notify the COR and PM within 30 minutes of detection or receipt of VA notification of any system outage, security event, or service interruption that affects solution availability, performance, or functionality. The Contractor shall provide:

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

1. An initial technical response to Critical incidents within 30 minutes of and shall resolve it by restoring core system functionality within two hours of detection or receipt of VA notification, regardless of time of day.
2. An initial technical response to Major incidents within one business hour of and shall resolve it by restoring functionality within four hours of detection or receipt of VA notification.
3. An initial technical response to Minor incidents within four business hours of and shall resolve it within eight business hours of detection or receipt of VA notification.
4. For all incidents, automated notifications to VA-designated distribution points, which may include the COR, PM, VA ticketing systems, or VA monitoring systems.

Critical incidents are defined as solution outages or security-related events that render the solution unavailable or pose an immediate risk to the confidentiality, integrity, or availability of FOIA or Privacy Act data. Major incidents are defined as issues that prevent submission, retrieval, review, redaction, or closure of FOIA requests. Minor incidents are defined as issues that degrade solution functionality without preventing FOIA processing.

User Support. For User support tickets that do not involve solution defects or incidents, the Contractor shall provide that user with a non-automated response within one business day and resolve the ticket within three business days, unless resolution requires VA action, policy clarification, or user follow-up.

Reporting. The Contractor shall maintain and provide a Weekly Help Desk Maintenance Log that delivers actionable insight into solution performance and support activity. At a minimum, the log shall include the number of tickets opened, closed, and pending; tickets exceeding defined Service Line Agreements (SLA) thresholds; incident severity classifications; SLA compliance for acknowledgment and resolution; summaries of critical and major incidents and their root causes; recurring issues and trends; system-impacting events; impacts to request intake, processing, or release activities; maintenance activities performed during the reporting period; and any risks or emerging issues under active monitoring. All notifications, response actions, resolution steps, and timelines shall be documented in the Weekly Help Desk Maintenance Logs.

Deliverable:

- A. Weekly Help Desk Maintenance Logs

5.5 EFOIA SOLUTION TRAINING

The Contractor shall provide training for VA staff to ensure effective use and administration of the COTS eFOIA SaaS solution. All training materials, user guides,

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

administrator guides, and recorded sessions shall comply with Section 508 accessibility requirements.

The Contractor shall provide initial training 10 business days after TO award, prior to Go Live. Initial training shall consist of 10 instances (one a week) of interactive instructor led Training with exercises & On demand videos. The Contractor shall provide a proposed Initial Training schedule which shall be executed after VA COR Approval of the schedule.

VA requires Recurrent Training that occurs after Go Live. The Contractor shall provide a COTS eFOIA SaaS Recurrent Training Plan that documents the approach, schedule, delivery method, and target audiences for scheduled recurrent training, which includes at a minimum virtual instructor-led and role-based training. Training shall cover all core user functions needed for request intake, assignment, review, redaction, correspondence, release, reporting, and system administration. The Contractor shall provide recurrenting instructor-led virtual training sessions which shall be provided on a weekly basis throughout the period of performance, with each session focused on different solution features, functions, or updates using a rotating topic schedule. The Contractor shall provide role-based training for FOIA Officers, reviewers, and system administrators, and shall provide ad hoc virtual training upon VA request to address solution updates, configuration changes, new features, or other solution changes that affect user performance. VA will provide at least five business days' notice for ad hoc training requests. Ad hoc training shall be provided at no additional cost to VA.

The Contractor shall provide a training environment or sandbox, separate from the production system, that allows VA users to practice solution system functions without affecting live data.

The Contractor shall provide and maintain an eFOIA Solution User Guide, an eFOIA System Administrator Guide, and all associated training materials. The Contractor shall update all guides and materials whenever solution functionality or configuration changes affect their accuracy. Updated materials shall be provided to VA in electronic format at least five business days prior to any scheduled recurrent training session.

All training sessions conducted by the Contractor shall be recorded and the Recorded Training Sessions shall be delivered to VA using Microsoft Teams or another VA approved platform within seven calendar days after the training.

Deliverables:

- A. Training Plan
- B. User Guide
- C. System Administrator Guide

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

- D. Training Materials including Training Environment or Sandbox
- E. Recorded Training Sessions

5.6 EFOIA LESSONS LEARNED

The Contractor shall provide an Annual eFOIA SaaS Project Activity Lessons Learned Report. The report shall identify significant challenges, risks, and successes encountered during this task order period of performance and shall document actionable lessons learned related to solution performance, configuration, operations, training, security, and support. For each identified lesson, the report shall describe the underlying cause, the impact to VA operations or users, and recommended improvements or corrective actions. The report shall also identify any lessons that were implemented during the reporting period and the outcomes of those actions.

Deliverable:

- A. Annual eFOIA SaaS Project Activity Lessons Learned Report

5.7 ASSESSMENT, AUTHORIZATION, AND CONTINUOUS MONITORING

5.7.1 IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA)
2. The Contractor shall remain in compliance with [FedRAMP](#) requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The system must be FedRAMP Authorized at no less than the Moderate.
4. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application.
5. The Contractor shall provide confirmation of the completion of its FedRAMP System Security Plan (SSP) and supporting documentation by providing, to the VA PM, COR, and Digital Transformation Center (DTC), its repository ID number and associated link for VA to download the SSP and all required artifacts within five calendar days of contract award.
6. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA specific system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

7. The Contractor shall provide the results of their most recent Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
9. The Contractor shall provide VA with the most recent monthly scans for the production environment within the authorization boundary and their scan upload schedule for FedRAMP within 30 calendar days of contract award.
10. The Contractor shall provide their availability to participate in monthly continuous monitoring meetings to be scheduled following successful VA ATO within 30 calendar days of contract award.
11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.
12. The Contractor shall comply with FedRAMP data management requirements.
13. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
14. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy.
15. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
16. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
17. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. VA Implementation Diagram
- B. 3PAO Security Assessment Plan (SAP)
- C. 3PAO Security Assessment Report (SAR)
- D. Plan of Action and Milestones Reports
- E. Monthly VA License Report

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

5.7.2 IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall remain in compliance with [FedRAMP](#) requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as Moderate.
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.
5. The Contractor shall exclusively provide subscription licenses to FedRAMP authorized and VA authorized environments.
6. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language. VA Privacy and Security deliverables as directed by the VA System owner.
7. The Contractor shall comply with FedRAMP data management requirements.
8. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
9. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP Website.
10. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by FedRAMP requirements.
11. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
12. The Contractor shall provide a Monthly VA License report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- A. Continuous Monitoring Monthly Scans
- B. Plan of Action and Milestones Reports.
- C. Monthly VA License Report

5.8 ENHANCED EXECUTIVE ANALYTICS AND DASHBOARD CAPABILITY

The Contractor shall provide an enhanced executive analytics dashboard capability designed to support senior leadership oversight and strategic management of the VA FOIA program. This capability shall supplement standard operational and statutory FOIA reporting by providing aggregated, trend-based, and summary-level views of FOIA workload, performance, and system utilization.

The executive dashboard shall present historical trends, workload forecasts, comparative performance metrics across organizational components, and configurable leadership views. The capability shall support drill-down from summary metrics to supporting data where appropriate and shall allow VA to tailor visualizations and views based on leadership needs.

The executive analytics capability shall leverage data already captured by the solution and shall not require changes to core FOIA intake, processing, review, or release workflows. The capability shall not be required for solution go live and shall not affect statutory FOIA processing or reporting if modified or removed.

The dashboard shall support export of reports and visualizations in commonly used formats and shall be accessible to designated VA leadership users with appropriate permissions.

Deliverable:

- A. Configured Executive Analytics and Dashboard Capability

5.9 OPTION PERIOD 1

If VA elects to exercise an option period, the Contractor shall continue performance of all requirements, services, and deliverables identified in this Performance Work Statement specifically 5.1, 5.1.1, 5.1.2, 5.2, 5.4, 5.5, 5.6, 5.7, and 5.8. Data Migration activities identified in Paragraph 5.3 are limited to the base period and shall not apply to any option period.

5.10 OPTION PERIOD 2

If VA elects to exercise an option period, the Contractor shall continue performance of all requirements, services, and deliverables identified in this Performance Work Statement specifically 5.1, 5.1.1, 5.1.2, 5.2, 5.4, 5.5, 5.6, 5.7, and 5.8. Data Migration activities identified in Paragraph 5.3 are limited to the base period and shall not apply to any option period.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

5.11 OPTION PERIOD 3

If VA elects to exercise an option period, the Contractor shall continue performance of all requirements, services, and deliverables identified in this Performance Work Statement specifically 5.1, 5.1.1, 5.1.2, 5.2, 5.4, 5.5, 5.6, 5.7, and 5.8. Data Migration activities identified in Paragraph 5.3 are limited to the base period and shall not apply to any option period.

5.12 OPTION PERIOD 4

If VA elects to exercise an option period, the Contractor shall continue performance of all requirements, services, and deliverables identified in this Performance Work Statement specifically 5.1, 5.1.1, 5.1.2, 5.2, 5.4, 5.5, 5.6, 5.7, and 5.8. Data Migration activities identified in Paragraph 5.3 are limited to the base period and shall not apply to any option period.

5.13 OPTIONAL TASK ONE – TRANSITION SUPPORT

If exercised by VA, the Contractor shall provide transition support for a period of not less than 90 days and up to 180 days before the end of the period of performance, as directed by VA, to facilitate an orderly transition from the Contractor to VA or a successor contractor. Transition support shall include technical assistance, system access and hosting as required, migration tools, documentation, and personnel support necessary to ensure continuity of FOIA operations. All transition activities shall be conducted under VA oversight and coordination and shall be completed prior to the end of the period of performance.

The Contractor shall develop and deliver a Transition Out Plan that describes the approach, schedule, roles, and responsibilities for transition activities. The Transition Out Plan shall include, at a minimum:

- a. Coordination with VA representatives and, when applicable, the incoming contractor under VA oversight. The Contractor shall not coordinate directly with an incoming contractor without VA knowledge and involvement.
- b. Transition, transfer, or destruction of FOIA data and files as directed by VA. When data destruction is directed, the Contractor shall provide written certification and evidence of completion in accordance with VA and federal records management and security requirements.
- c. Support to validate that migrated data and native content function as intended in the receiving system, including assistance with data verification, issue identification, and remediation during the transition period.
- d. Transfer of all business, technical, operational, and security documentation developed or used under this contract, including system configuration details,

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

workflows, interfaces, data schemas, API(s), and operating procedures necessary to support continued operations.

e. An orientation and knowledge transfer approach to support continuity of operations, including walkthroughs, briefings, or training sessions that explain system functionality, administrative processes, workflows, and known operational considerations to VA and, when directed, incoming contractor personnel.

This optional task may be exercised once during the base period or any option period at VA discretion.

Deliverable:

A. Transition Out Plan

5.14 OPTIONAL TASK TWO – ADDITIONAL STORAGE

If VA chooses to exercise this optional task, the Contractor shall provide up to 20 terabytes of additional storage per exercise for the eFOIA SaaS solution. Each exercise of this optional task shall add incremental storage capacity to the solution. This optional task may be exercised multiple times during the base period and any option period, up to a maximum of 18 exercises for a total of up to 360 terabytes of additional storage. All data stored using this additional capacity shall be managed in accordance with applicable NARA records retention schedules.

5.15 OPTIONAL TASK THREE – ADDITIONAL CONCURRENT USERS

If VA chooses to exercise this optional task, the Contractor shall provide the ability to support up to 10 additional concurrent users of the COTS eFOIA SaaS solution per exercise. This optional task may be exercised multiple times during the base period and any option period, up to a maximum of 18 exercises for a total of up to 180 additional concurrent users.

5.16 OPTIONAL TASK FOUR – APPLICATION PROGRAMMABLE INTERFACES (API) INTEGRATION ENABLEMENT AND CONFIGURATION

If VA chooses to exercise this optional task, the Contractor shall develop not to exceed four API(s). The API(s) shall integrate the solution with a VA-designated Privacy, records management, identity, reporting, or other VA information management system (IMS) so that the solution and the IMS can interoperate, communicate and exchange data. The API(s) must be compliant with the FOIA Improvement Act. VA will provide the Contractor with the names of each system that the API(s) will integrate the solution with when this task is exercised. The Contractor shall adhere to VA API Standards, found at: <https://department-of-veterans-affairs.github.io/va-api-standards/>, to develop the API(s).

The Contractor shall implement all integrations in a manner that also allows future configuration changes. The API(s) shall be consistent with all authentication and

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

authorization controls and all applicable Federal cybersecurity controls, as outlined in the VA API Standards.

The Contractor shall test the API(s) to validate that:

1. The solution interoperates, communicates and/or exchanges data with the intended system(s).
2. The API(s) accesses and contains all data fields of the solution so that VA or the IMS can access all the solution data.

The Contractor shall maintain the API(s) to include enabling or disabling interfaces and supporting new integrations as VA requirements evolve. The Contractor shall maintain the API(s) content manager (e.g., using a content manager tool such as the Swagger Content Manager tool) and the data dictionary to accurately reflect the data contained in the solution, and notify the VA COR when each has been updated for the solution. The Contractor shall provide the API(s) content manager and the updated data dictionary.

This optional task may be exercised up to four (4) times per period of performance.

Deliverables:

- A. Configured, Operational and Integrated API(s)
- B. API(s) Content Manager

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using [VA Enterprise Architecture \(EA\)](#), and VA Identity and Access Management (IAM) approved [Enterprise Technology Guidelines \(ETG\)](#). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion based authentication, and/or trust based authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda [M-05-24](#), [M-19-17](#), [M-22-09](#), and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 “USGv6 Profile” (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

(IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, Update to the Trusted Internet Connections (TIC) Initiative (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 Secure External Connections, and shall comply with the TIC 3.0 Core Guidance Documents, including all volumes and TIC use cases, issued by the Cybersecurity and Infrastructure Security Agency (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>).

Any deviation from TIC 3.0 requirements or use cases shall require prior written approval from VA through the applicable TIC governance and review process. The Contractor shall support VA by providing all technical documentation, implementation details, and supporting information necessary to evaluate and approve any requested deviation.

6.1.6 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, Windows 10 (64bit) and Windows 11, Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10 and or Windows 11 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

6.1.7 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the Veteran-Focused Integration Process (VIP) Guide and Product Line Management (PLM) Playbook. The major focus of VIP is on Enterprise Oversight, Governance, reporting, and establishing practices that focus on outcomes and continuously delivering sustainable IT capabilities to benefit the Veteran. PLM is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Transformation Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Transformation Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

The VIP Guide provides guidance for transitioning from project-centric to product-centric delivery. The VIP guide applies to all OIT Office of Management and Budget (OMB) reportable products that are required to collect and report costs, schedules, risks, and other valuable information in VA PARS (whether products are procured or developed by VA) and any VA Information Technology project effort in Software Product Management (SPM) and Infrastructure Operations (IO), or their successors, that touch the VA network regardless of IT organizational alignment (whether it spends government funding from VA's Congressional IT Appropriation or any other appropriation).

The PLM Transformation Playbook details how OIT leadership expects Product Lines (PLs) to implement PLM, DevOps, and Lean-Agile principles, methods, practices, and techniques through levels of maturity. The PLM Transformation Playbook applies to all Information Technology (IT) products aligned to PLs in the Software Product Management, Infrastructure Operations and Product Engineering organizations within the OIT organization.

Others outside the referenced groups or organizations may use the VIP Guide and PLM Transformation Playbook for situational awareness as needed.

6.1.8 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The Process Asset Library (PAL) includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB_ext.docx \(live.com\)](#). The main PAL can be accessed at www.va.gov/process.

6.1.9 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
5. Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for qualifying active duty military service in VA.
7. Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
8. Interfacing with Enterprise Mission Assurance Support Service (eMASS) to access the Authority to Operate (ATO) status of all VA Information Systems. eMASS contains the official Authority to Operate (ATO) status of all VA Information Systems.

6.1.10 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.2 SECURITY AND PRIVACY REQUIREMENTS

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☐	☒	☐
5.2	☐	☒	☐
5.3	☐	☒	☐
5.4	☐	☒	☐
5.5	☐	☒	☐
5.6	☐	☒	☐
5.7	☐	☒	☐
5.8	☐	☒	☐
5.9	☐	☒	☐
5.10	☐	☒	☐
5.11	☐	☒	☐
5.12	☐	☒	☐
5.13	☐	☒	☐
5.14	☐	☒	☐
5.15	☐	☒	☐
5.16	☐	☒	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- b. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 business day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)
- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 business days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM)

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the Security and Investigation Center (SIC).

- f. The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a “click to sign” process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed “Contractor Rules of Behavior”, and with a valid, operational PIV credential for PIV-only logical access to VA’s network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
- k. Personal Identity Verification (PIV) Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

A. Contractor Staff Roster

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include:

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment will be used by the COR in accordance with the QASP to assess Contractor performance.

6.5 FACILITY/RESOURCE PROVISIONS

The Government will provide office space, telephone service and system access when authorized contract staff work at a Government location as required in order to accomplish the Tasks associated with this PWS. All procedural guides, reference materials, and program documentation for the project and other Government applications will also be provided on an as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) and now the Azure Virtual Desktop (AVD) (as VA is currently transitioning from CAG to the AVD), are the current and only VA approved methods for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this are countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information System Security Officer (ISSO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

6.6 GOVERNMENT FURNISHED PROPERTY

Not applicable.

6.7 SHIPMENT OF HARDWARE OR EQUIPMENT

Not applicable.

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring.

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 (Appendix C updated April 22, 2024) by reference

Modernized Enterprise eFOIA SaaS Solution VA-26-00037131

as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](https://www.access-board.gov/section-508/). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with “508 Chapter 2: Scoping Requirements” for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.

3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and EPHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
 - a. The use of "thumb drives" or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

DRAFT

**Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131**

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM
SECURITY/ PRIVACY LANGUAGE**

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/
PRIVACY LANGUAGE**

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: *VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE*

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.
- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.

- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.
- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
 - (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
 - (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
- g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].
- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five business days of the initiation of the contract and annually thereafter, as required.
- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
-
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
 - d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
 - e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
 - f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
 - g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
 - h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

Not Applicable

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).

- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.
- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.

- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b):

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.

- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.

- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.
- c. The Contractor shall provide or arrange for the provision of technical justification as to why any "false positive" hit has taken place to ensure their code's supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.

- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor’s products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA’s assets. This documentation will include information regarding the following:

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
 - c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 business days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
 - d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

Not applicable.

B14. DATA CENTER PROVISIONS

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.

Modernized Enterprise eFOIA SaaS Solution
VA-26-00037131

POINTS OF CONTACT

VA Program Manager:

Name:
Address:
Voice:
Email:

Contracting Officer's Representative:

Name:
Address:
Voice:
Email:

Contracting Officer:

Name:
Address:
Voice:
Email:

Contract Specialist:

Name:
Address:
Voice:
Email: